

Incident Analysis Report

Index

Incident Analysis Report	0
Index	0
Executive Summary	2
Technical Analysis	3
Affected Systems & Data	3
Evidence Sources & Analysis	3
Indicators of Compromise (IoCs)	4
Root Cause Analysis	4
Nature of the Attack	4
1. March 25, 2023, 15:52: Ransom.CryptXXX detected on jdoe-pc by endpoint protection.	4
2. March 25, 2023, 15:52: Malicious traffic initiated to C2 server (128.31.0.39) over SMB (Port 445).	4
3. March 25, 2023, 15:53: Files on John Doe’s workstation encrypted by ransomware.	4
Impact Analysis	4
Thought Process	4
The IP is categorized as Malicious and Anonymizers. Its association with anonymization services like Tor may contribute to this classification.	6
Firewall Log:	6
• Analyzed the firewall logs and identified outbound traffic from 10.20.20.32 (John Doe’s workstation) to 128.31.0.39 (destination IP).	6
• Correlated the destination port (445) and service (SMB) with known ransomware behaviors, confirming it was used for communication with the C2 server.	6
• Verified that traffic was allowed due to a default "Allow All" firewall policy.	6
Root Cause Analysis	7
Findings:	7
The dork queries revealed potential sources hosting or referencing the file, enabling further exploration of associated URLs, servers, or compromised systems. This step enriched the threat intelligence and confirmed that the hash was actively present in the wild.	7
Response and Recovery Analysis	8
Immediate Response Actions	8
Eradication Measures	8
Recovery Steps	8
Post-Incident Actions	8
Technical Timeline	9

Executive Summary

Incident ID: INC2023-0325-001

Incident Severity: Critical (P1)

Incident Status: Resolved

Incident Overview: On March 25, 2023, at approximately 15:52, a ransomware attack encrypted files on John Doe's workstation. The attack originated from a phishing email containing a malicious attachment. Endpoint security logs and firewall activity confirmed the execution of ransomware and communication with a Command and Control (C2) server.

Key Findings:

- The attack was caused by user interaction with a phishing email.
- Endpoint protection policies were misconfigured, allowing ransomware execution.
- Malicious traffic was allowed to the C2 server due to firewall misconfigurations.

Immediate Actions:

- Isolated the affected workstation.
- Blocked malicious IP and traffic on SMB (Port 445).
- Reset credentials for the affected user.

Stakeholder Impact:

- Files on John Doe's device were encrypted, but no sensitive data was exfiltrated.

Technical Analysis

Affected Systems & Data

- **System:** jdoe-pc (User: John Doe, ACME Sales HQ group).
- **Data Impacted:** Local files on the workstation were encrypted by ransomware.

IP	Hostname
10.20.20.32	jdoe-pc (User: John Doe, ACME Sales HQ group).

Evidence Sources & Analysis

Endpoint Protection Log:

- **Threat Detected:** Ransom.CryptXXX, linked to WannaCry ransomware.
- **SHA256 Hash:**
ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa.
- **Source IP:** 10.20.20.32 (John Doe's machine).
- **Occurrences:** 4 detections, no remediation due to endpoint policy misconfiguration.
- **Reference (VirusTotal Analysis):** [Link to VirusTotal analysis.](#)

Firewall Log:

- **Source IP:** 10.20.20.32 (John Doe's machine).
- **Destination IP:** 128.31.0.39 (MIT server used as Command and Control infrastructure).
- **Protocol/Port:** SMB (445).
- **Action:** Traffic allowed due to misconfigured firewall rules.

Shodan Analysis:

- The IP 128.31.0.39 is associated with MIT's Computer Science and Artificial Intelligence Lab (CSAIL).
- The server was potentially misused as part of a Command and Control (C2) infrastructure.

Indicators of Compromise (IoCs)

- **File Hash:**
ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa.
- **C2 IP Address:** 128.31.0.39.
- **Protocol/Port:** SMB (445).

Root Cause Analysis

- **Initial Vector:** Phishing email containing a malicious attachment was sent to John Doe.
- **Execution:** User opened the attachment, which executed ransomware.
- **Policy Misconfiguration:** Endpoint protection was set to “leave threats alone,” enabling execution.
- **Firewall Misconfiguration:** Allowed outbound SMB traffic to the C2 server.

Nature of the Attack

1. **March 25, 2023, 15:52:** Ransom.CryptXXX detected on jdoe-pc by endpoint protection.
2. **March 25, 2023, 15:52:** Malicious traffic initiated to C2 server (128.31.0.39) over SMB (Port 445).
3. **March 25, 2023, 15:53:** Files on John Doe’s workstation encrypted by ransomware.

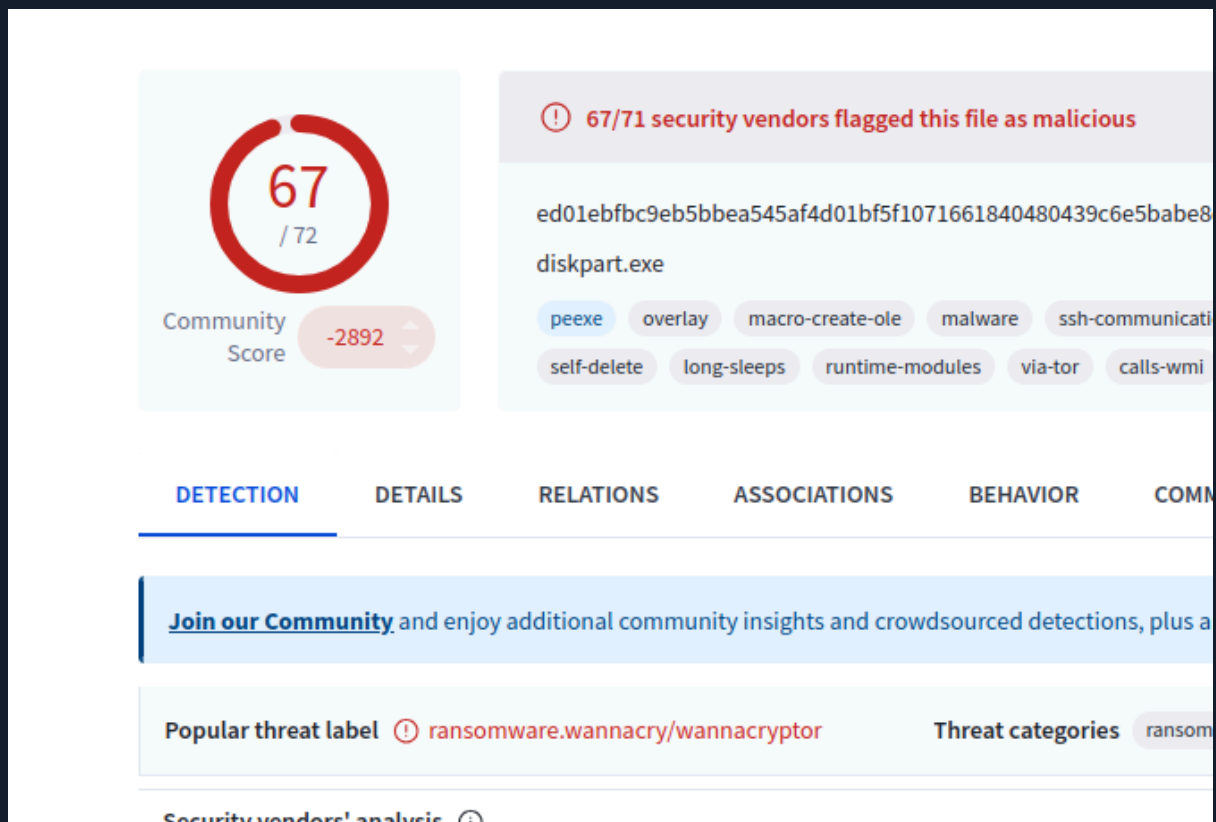
Impact Analysis

- **Business Impact:**
 - Minimal operational disruption; the issue was contained before spreading.
 - No sensitive data exfiltrated.
- **User Impact:**
 - John Doe’s workstation required reimaging and file restoration.

Thought Process

Hash Analysis:

- Started by searching the file hash (ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa) on VirusTotal.
- Observed that 67/72 engines flagged it as malicious, identifying it as a WannaCry variant.
- Collected details of the associated file name (diskpart.exe) and related IoCs.



67 / 72

Community Score -2892

67/71 security vendors flagged this file as malicious

ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe80e41aa

diskpart.exe

peexe overlay macro-create-ole malware ssh-communicati

self-delete long-sleeps runtime-modules via-tor calls-wmi

DETECTION DETAILS RELATIONS ASSOCIATIONS BEHAVIOR COMM

[Join our Community](#) and enjoy additional community insights and crowdsourced detections, plus a

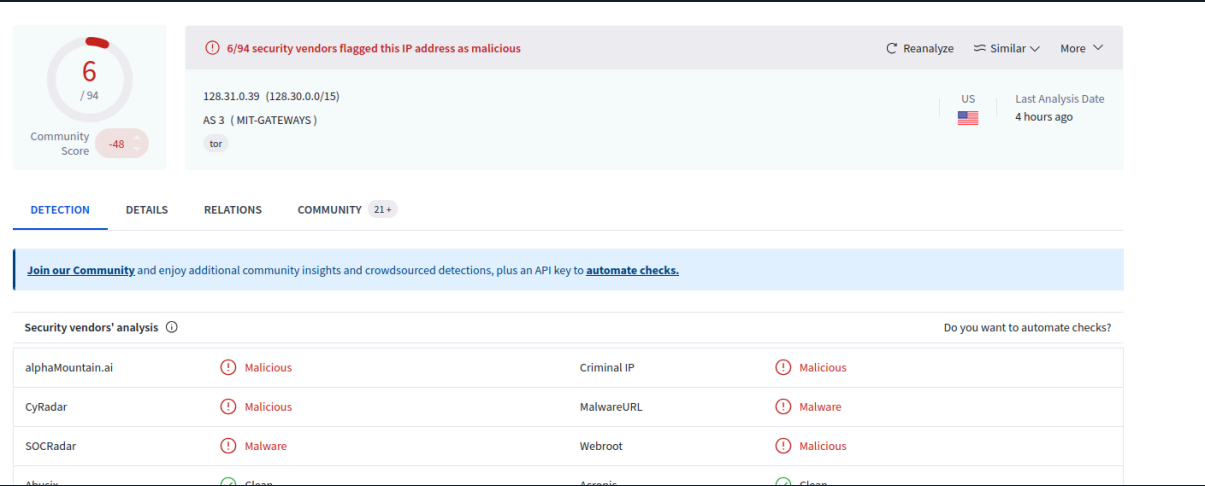
Popular threat label ⚠ ransomware.wannacry/wannacryptor Threat categories ransom

Security vendors' analysis ⓘ

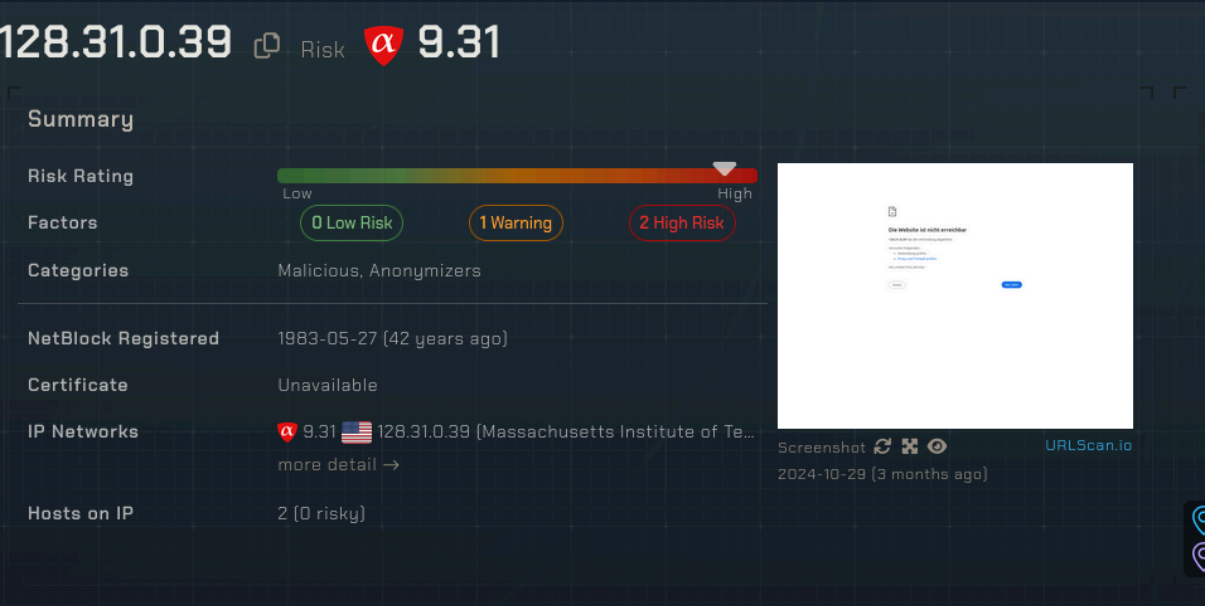
IP Address Investigation:

- Queried the C2 IP (128.31.0.39) with a custom Shodan-based tool to [retrieve](#) geolocation and ownership details.
- Found it belongs to MIT's CSAIL and identified open ports like 22 (SSH). This indicated potential misuse as part of C2 infrastructure.

```
/tmp/work » echo 128.31.0.39 | elips -
128.31.0.39 (belegost.csail.mit.edu)
Ports: 22
CPes: cpe:/o:debian:debian_linux, cpe:/o:linux:linux_kernel, cpe:/a:openbsd:openssh:9.2p1
```



The IP is categorized as **Malicious** and **Anonymizers**. Its association with anonymization services like Tor may contribute to this classification.



Firewall Log:

- Analyzed the firewall logs and identified outbound traffic from 10.20.20.32 (John Doe's workstation) to 128.31.0.39 (destination IP).
- Correlated the destination port (445) and service (SMB) with known ransomware behaviors, confirming it was used for communication with the C2 server.
- Verified that traffic was allowed due to a default "Allow All" firewall policy.

Correlations:

- Combined endpoint logs, VirusTotal results, and firewall logs to confirm the ransomware executed on **jdoe-pc**, communicated with **128.31.0.39** via SMB, and encrypted local files.

Hash Investigation via Google Dorks:

To identify additional contexts and potential instances of the malicious file hash (**ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa**), I used [Google dork](#) queries using a custom tool:

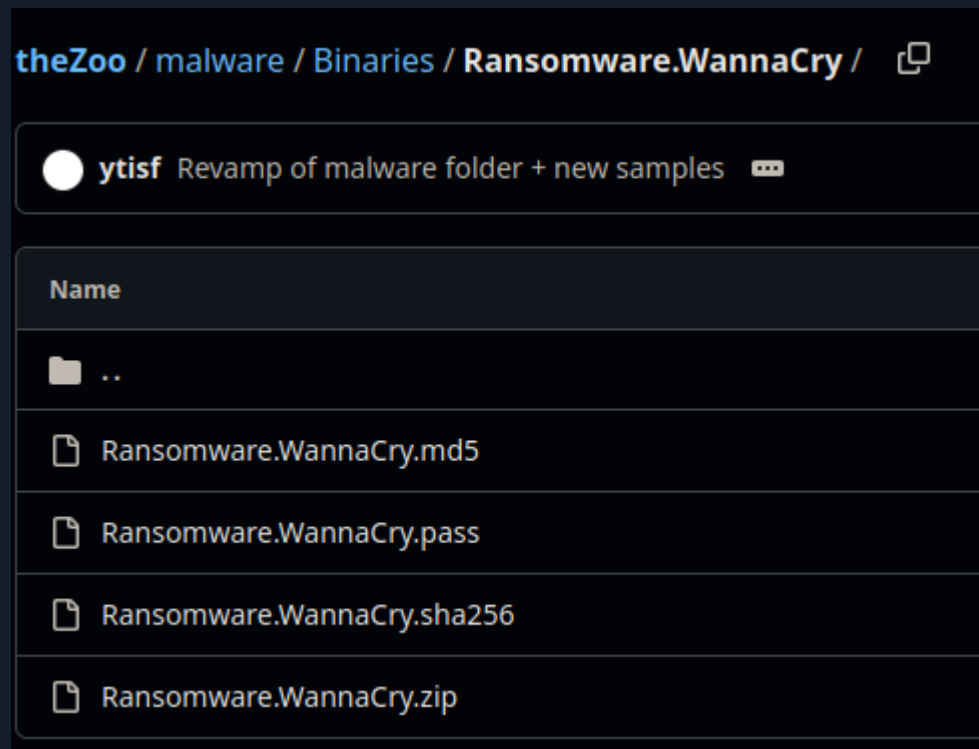
```
/tmp/work » banshee --url .com --query "(intext:\`ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa\` | inurl:\`ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa\`)\" --pages 10 --recursive
https://github.com/Neo23x0/signature-base/blob/master/yara/crime_wannacry.yar
https://nikhilh20.medium.com/malware-analysis-wannacry-b0d35f1b2033
https://www.criticalstart.com/wannacry-iocs-and-technical-details/
https://www.hybrid-analysis.com/sample/ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa?environmentId=100
https://www.virustotal.com/en/File/ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa/analysis/https://chesterrep.openrepository.com/bitstream/handle/10034/624279/Talos.pdf?sequence=1&isAllowed=n
https://discuss.rapid7.com/t/convert-json-or-string-to-array/26308
https://github.com/demisto/content/blob/master/Packs/CyLance_Protect/Integrations/CyLance_Protect_v2/README.md
https://github.com/Neo23x0/signature-base/blob/master/yara/crime_wannacry.yar
https://medium.com/@qadeerbilal91/the-anatomy-of-wannacry-a-thorough-investigation-into-exploits-spread-strategies-and-encryption-c05d42534189
https://www.fortinet.com/blog/threat-research/wannacry-ransomware
https://www.mcafee.com/blogs/other-blogs/executive-perspectives/analysis-wannacry-ransomware-outbreak/
https://www.secureworks.com/research/wcry-ransomware-analysishttps://blog.avast.com/de/ransomware-die-telefonica-und-nhs-krankenhaus%C3%A4user-infiziert-hat-breitet-sich-aggressiv-aus.-bisher-fanden-mehr-als-50.000-angriffe-statt
https://blog.avast.com/ransomware-that-infected-telefonica-and-nhs-hospitals-is-spreading-aggressively-with-over-50000-attacks-so-far-today
https://blog.talosintelligence.com/wannacry/
https://temasoft.com/live-ransomware-attack-video/
https://www.cnblogs.com/bonelee/p/16077358.html
https://www.comae.com/posts/wannacry-the-largest-ransom-ware-infection-in-history/
https://www.reddit.com/r/antivirus/comments/1i59jza/does_anyone_have_a_virtustotal_sample_with_100/
```

Findings:

The dork queries revealed potential sources hosting or referencing the file, enabling further exploration of associated URLs, servers, or compromised systems. This step enriched the threat intelligence and confirmed that the hash was actively present in the wild.

GitHub Dorking:

- Queried the hash (**ed01ebfbc9eb5bbea545af4d01bf5f1071661840480439c6e5babe8e080e41aa**) on [GitHub](#) using search queries for malware samples.
- Found repositories containing the hash linked to ransomware samples, providing additional evidence of malicious use.



Response and Recovery Analysis

Immediate Response Actions

1. Isolated the affected device by disconnecting it from the network.
2. Blocked malicious IP (**128.31.0.39**) and SMB traffic (Port 445) at the firewall.
3. Reset John Doe's credentials to prevent further compromise.

Eradication Measures

1. Removed ransomware files from the affected computer.
2. Updated endpoint protection policies to automatically quarantine threats.
3. Conducted a network-wide scan to ensure no lateral movement occurred.

Recovery Steps

1. Restored encrypted files from clean, secure backups.
2. Reimaged John Doe's workstation to eliminate potential residual threats.
3. Validated system security and functionality before redeployment.

Post-Incident Actions

1. **Monitoring and Configuration:**
 - Enhanced SIEM rules to detect similar behaviors (e.g., mass file encryption, unusual SMB traffic).
 - Enabled advanced email security filters to block phishing attempts.

- Reconfigured antivirus to take automatic action (quarantine/delete threats) instead of "leaving them alone."
 - Ensured SMB versions are updated, disable SMBv1 if still enabled, and restrict SMB traffic to internal IP ranges.
2. **Lessons Learned:**
- Endpoint protection policies must enforce automatic remediation.
 - Firewall rules should restrict unnecessary outbound traffic, especially on high-risk ports like SMB (445).
3. **Recommendations:**
- Conduct phishing awareness training for employees.
 - Regularly patch systems and update antivirus signatures.
 - Implement threat intelligence feeds to enrich SIEM alerts.

Attack Analysis Using MITRE ATT&CK Framework

- **T1566.001 – Phishing: Spear Phishing Attachment**
 - Initial infection vector via a crafted email targeting John Doe.
 - [Learn more.](#)
- **T1204.002 – User Execution: Malicious File**
 - Execution of ransomware triggered by user interaction with the phishing email.
 - [Learn more.](#)
- **T1547 – Boot or Logon Autostart Execution**
 - Likely use of persistence mechanisms, though not directly captured in logs.
 - [Learn more.](#)
- **T1562 – Impair Defenses**
 - Endpoint defenses bypassed due to misconfigured automatic remediation.
 - [Learn more.](#)
- **T1021.002 – SMB/Windows Admin Shares**
 - Potential lateral movement or data exfiltration using SMB traffic.
 - [Learn more.](#)
- **T1486 – Data Encrypted for Impact**
 - The final stage involved encrypting files on John Doe's device.
 - [Learn more.](#)

Annex A

Technical Timeline

Time	Activity
March 25, 2023, 15:52	Ransom.CryptXXX detected on jdoo-pc .
March 25, 2023, 15:52	Malicious traffic initiated to C2 server (128.31.0.39).
March 25, 2023, 15:53	Files encrypted on John Doe's workstation.
March 25, 2023, 16:00	Affected device isolated from the network.
March 25, 2023, 16:15	Firewall rules updated to block malicious IP.
March 25, 2023, 16:30	Incident response actions completed.